

INFORME DE EVALUACIÓN DE SEGURIDAD

Evaluación de Seguridad Ofensiva, Hackeo Ético y Verificación OWASP ASVS v4.0.3

NOVIEMBRE DE 2026

CONFIDENCIAL - REPORTE DE SEGURIDAD E INFORMACIÓN DE AUDITORÍA

Índice / Tabla de Contenidos

1. Resumen Ejecutivo y Ficha Técnica ..... Pág. 3

2. Metodología de Evaluación y Estándares Aplicados ..... Pág. 4

2.1 Marcos utilizados ..... Pág. 4

2.2 Escala de severidad y prioridad ..... Pág. 4

3. Gráficos de Distribución (Score (CVSS)) ..... Pág. 5

4. Gráficos de Distribución (Estado del Ticket) ..... Pág. 6

5. Alcance técnico y componentes evaluados ..... Pág. 7

6. Hallazgos identificados ..... Pág. 8

7. Listado Resumido y Detalle de Hallazgos (1 tickets) ..... Pág. 9

8. Conclusiones y plan de remediación recomendado ..... Pág. 10

Resumen Ejecutivo y Ficha Técnica

Este informe reúne los resultados y hallazgos identificados durante las pruebas de penetración y la evaluación de seguridad d e la plataforma evaluada.

El objetivo de la evaluación es identificar vulnerabilidades que podrían ser aprovechadas para afectar la seguridad del sistem a. Los resultados permiten priorizar las correcciones y reducir los riesgos para la organización.

Parámetro / Campo Detalle de la Evaluación	
Tipo de Evaluación	Prueba de seguridad de caja negra
Estándar Principal	OWASP ASVS 4.0.3, CVSS 3.1
Período de Pruebas	9 de noviembre de 2026
Entorno de Evaluación	Laboratorio educativo Asistencia de Software Seguro
Clasificación del Documento	**ESTRICTAMENTE CONFIDENCIAL**

Metodología de Evaluación y Estándares Aplicados

La evaluación se realizó mediante pruebas dinámicas de caja negra, utilizando Burp Suite para interceptar, modificar y repetir solicitudes HTTP. Se compararon los mensajes, encabezados y tiempos de respuesta de la aplicación.

Técnicas utilizadas:

- Pruebas manuales con Proxy y Repeater.
- Enumeración automatizada con Intruder de los códigos `000` a `999`, manteniendo una clave incorrecta fija.
- Comparación de tiempos mediante la columna `Response received`.
- Validación de la cantidad inferida mediante la aceptación de su hash MD5 como flag del laboratorio.

Alcance de las pruebas: formulario de consulta del laboratorio Asistencia, endpoint `POST /index.php` y parámetros `codigo` y `clave`.

No se contó con acceso al código fuente ni a la base de datos. La causa interna de la diferencia temporal no pudo determinar se. Tampoco se conservaron mediciones exactas ni se realizó un análisis estadístico de repetibilidad.

2.1 Marcos utilizados

- **OWASP ASVS 4.0.3:** referencia general para revisar los controles de seguridad. No se realizó una verificación completa d e sus requisitos ni se determinó cumplimiento de un nivel.
- **CVSS 3.1:** metodología utilizada para estimar la severidad técnica del hallazgo.

2.2 Escala de severidad y prioridad

Se utiliza CVSS 3.1 para expresar el puntaje, la severidad y el vector del hallazgo. La prioridad de corrección debe considerar t ambién la sensibilidad de la información y el contexto del sistema.

El hallazgo recibió una valoración propuesta de **5.3 — Media**, con el vector:

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`

Escala			
Baja (0.1 – 3.9)	Media (4.0 – 6.9)	Alta (7.0 – 8.9)	Crítica (9.0 – 10.0)

Métricas y Distribución Estadísticas de Hallazgos

A continuación se consolidan las métricas obtenidas sobre el estado actual de los hallazgos técnicos registrados durante la a uditoría.



Distribución de los hallazgos según su puntaje CVSS. La gráfica permite comparar su severidad e identificar cuáles requieren mayor atención

Distribución por Estado del Ticket



CATEGORÍA	CANT.	%
Validado	1	100.0%

Total contabilizado: 1

La gráfica muestra la proporción de hallazgos según su estado actual. Esta información permite conocer el avance del seguimiento y de las tareas de corrección

Alcance técnico y componentes evaluados

La evaluación se limitó al formulario de consulta del laboratorio **Asistencia**, al endpoint `POST /index.php` y a sus parámetros `codigo` y `clave`.

Validación de la clave y restricción de consulta: se revisó el comportamiento de la aplicación al consultar distintos códigos con una clave incorrecta. No se evaluaron roles ni permisos de cuentas autenticadas.

Validación de entradas: se modificó el parámetro `codigo`, se probó la ausencia del parámetro `clave` y se enumeraron los códigos de `000` a `999`. Las pruebas realizadas no confirmaron una inyección SQL.

Divulgación de información: se compararon los mensajes, encabezados y tiempos de respuesta. Las diferencias temporales permitieron inferir una cantidad de 159 asistentes, confirmada mediante la aceptación de la flag.

Manejo de errores: se revisaron las respuestas buscando errores internos, trazas o información técnica sensible. En las respuestas inspeccionadas no se observaron estos datos.

No se evaluaron la gestión completa de sesiones, la configuración TLS, los mecanismos criptográficos internos ni el registro de eventos del servidor. El cálculo de MD5 se utilizó únicamente para generar la flag exigida por el laboratorio.

Hallazgos identificados

A continuación se documentan los hallazgos confirmados durante la evaluación. Para cada uno se incluyen el resumen, los det alles técnicos, las métricas CVSS, la prueba de concepto paso a paso y las recomendaciones de remediación.

HALLAZGO #1 Validado

Software Seguro v1.0.1

Plantilla: Plantilla
Ref ID: 003

TITULO

Divulgación de la cantidad de asistentes mediante diferencias en los tiempos de respuesta

TIPO

Information Disclosure

SEVERIDAD

Baja

DESCRIPCIÓN

El endpoint POST /index.php permite inferir la cantidad de asistentes mediante diferencias en los tiempos de respuesta, aun cuando se proporciona una clave incorrecta. Aunque la aplicación muestra el mismo mensaje de rechazo, las diferencias temporales permiten distinguir un grupo de códigos.

SCORE

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

IMPACTO

Un usuario sin la clave de consulta puede inferir la cantidad de asistentes. El comportamiento temporal revela información que la aplicación pretende restringir.

PRUEBA DE CONCEPTO (POC)

1. Capturar con Burp Suite la petición POST a `/index.php`, con el cuerpo `codigo=001&clave=hola`.
2. Enviar la petición a Intruder y seleccionar únicamente el valor de `codigo` como posición de payload.
3. Configurar una secuencia numérica desde 000 hasta 999, manteniendo tres dígitos y una clave incorrecta fija.
4. Ejecutar las solicitudes y ordenar los resultados por la columna `Response received`, de mayor a menor.
5. Observar un grupo de 159 respuestas con tiempos notablemente mayores, aunque el mensaje visible continúa siendo “No se puede acceder a esta información”.
6. Inferir una cantidad de 159 asistentes y calcular el MD5 del texto `159`, sin espacios ni salto de línea.
7. Enviar el resultado `140f6969d5213fd0ece03148e62e461e`, aceptado por el laboratorio como flag.

Resultado: las diferencias temporales permitieron inferir la cantidad de asistentes sin

conocer la clave. No se determinó la operación interna que provoca la demora.

RECOMENDACIÓN

Validar la autorización antes de consultar información asociada al código y reducir las diferencias temporales entre consultas rechazadas. Complementar con límites de frecuenc ia y monitoreo de enumeración. Verificar la corrección mediante mediciones repetidas.

Conclusiones y plan de remediación recomendado

La evaluación identificó una divulgación de información mediante diferencias en los tiempos de respuesta. Aunque la aplicación rechazó las consultas con una clave incorrecta, su comportamiento temporal permitió inferir la cantidad de asistentes registrados: **159**. La aceptación del MD5 de esa cantidad como flag confirmó el resultado.

El hallazgo recibió una valoración propuesta de **severidad media (CVSS 3.1: 5.3)**. El impacto comprobado se limita a la divulgación de la cantidad de asistentes; no se demostró acceso a datos personales, modificación de información ni afectación de la disponibilidad.

Se recomienda el siguiente plan de remediación:

- **Revisar el procesamiento de las consultas:** identificar qué operación produce diferencias temporales entre códigos cuando la clave es incorrecta.
- **Corregir el canal de divulgación:** evitar que las consultas rechazadas ejecuten operaciones distinguibles según la existencia del código. Mantener un mensaje genérico es necesario, pero no elimina por sí solo la filtración temporal.
- **Incorporar controles complementarios:** limitar la frecuencia de consultas y registrar patrones de enumeración, sin depender únicamente de estas medidas para corregir el problema.
- **Realizar una reevaluación:** repetir mediciones sobre códigos existentes e inexistentes, controlar la variación de red y comprobar que ya no puedan distinguirse de forma consistente. Verificar también que las consultas autorizadas continúen funcionando.

La causa interna de la demora deberá confirmarse mediante una revisión del código y del procesamiento del servidor.

Informe elaborado por: Gabriel Agustín, Bertero Jarchum.

Revisión: pendiente.